

Киберстрахование в РБ и пентест: когда отчет спасет выплату, а когда похоронит бизнес

 redsec.by/article/kiberstrahovanie-v-rb-i-pentest-kogda-otchet-spaset-vyplatu-a-kogda-pohoronit-biznes

Red Teams | 12 января 2026



В среде топ-менеджмента и даже среди некоторых IT-директоров бытует опасное заблуждение: отчет по пентесту (тестированию на проникновение) — это сугубо технический документ "для галочки" или для внутреннего пользования администраторов. Считается, что его задача — показать уязвимости, чтобы их когда-нибудь исправили. Однако в контексте управления рисками и финансовой защиты бизнеса роль этого документа кардинально меняется.

Для страховой компании отчет по пентесту — это не просто список багов. Это юридический артефакт, способный стать либо вашим "золотым парашютом", гарантирующим многомиллионную выплату, либо доказательством вашей халатности, которое позволит страховщику законно отказать в покрытии убытков.

В этой статье мы подробно разберем, как качественный пентест влияет на андеррайтинг, почему игнорирование рекомендаций аудиторов равносильно добровольному отказу от страховки и какова специфика этого процесса в реалиях Беларуси и международной практики.

1. Ландшафт киберстрахования в Беларуси: между "имуществом" и цифровой реальностью

Рынок киберстрахования в Республике Беларусь находится на этапе становления. В отличие от развитых рынков США или ЕС, где *Cyber Insurance* — это отдельная, строго регламентированная индустрия с устоявшимися актуарными моделями, в Беларуси мы наблюдаем период "гибридной адаптации".

Законодательный вакуум и рыночная практика

На данный момент в белорусском законодательстве отсутствуют специализированные нормы, детально регулирующие именно киберстрахование. Понятия "киберриск", "киберинцидент" или "страхование информационных активов" слабо проработаны в нормативно-правовой базе, регулирующей страховую деятельность.

Однако это не значит, что рынка нет. Он существует, но в специфической форме:

- **Включение в классические полисы:** Киберриски часто "вкручивают" как дополнительную опцию (endorsement) в договоры страхования имущества, ответственности директоров (D&O) или страхования от перерывов в производстве (Business Interruption).
- **Основные игроки:** Крупные государственные и частные страховщики (например, Белгосстрах и другие лидеры рынка) предлагают покрытие, но чаще всего рассматривают его через призму классических видов убытков.
- **Политический вектор:** На государственном уровне уже звучат тезисы о необходимости формирования национальной системы киберстрахования как элемента стратегии национальной безопасности. Это сигнал бизнесу: правила игры скоро станут жестче.

Заимствование западной логики

Поскольку локальной статистики инцидентов для построения качественных математических моделей риска в РБ недостаточно, белорусские андеррайтеры и перестраховщики неизбежно опираются на зарубежный опыт. Методики оценки рисков, опросники и условия выплат заимствуются из практики Lloyd's of London, Allianz, AXA и других гигантов.

Это означает, что для белорусской компании, желающей застраховать свои цифровые риски, будут применяться те же жесткие требования к безопасности, что и для компании в Нью-Йорке или Берлине. Договоры и методики андеррайтинга в РБ будут адаптировать западную логику под нормы Гражданского кодекса РБ. Поэтому понимание международной механики процесса критически важно для любого CISO или финансового директора в Беларуси.

2. Анатомия андеррайтинга: как страховщик оценивает ваш "цифровой иммунитет"

Прежде чем выдать полис, страховая компания запускает процесс андеррайтинга (underwriting). Это комплексный анализ, цель которого — ответить на три вопроса:

- Можно ли брать этого клиента на борт?
- Какие исключения и лимиты ответственности прописать в договоре?
- Сколько должна стоить страховая премия (цена полиса)?

В классическом страховании (например, КАСКО) все просто: есть марка машины, год выпуска и стаж водителя. В киберстраховании все сложнее, так как ландшафт угроз меняется ежедневно. Андеррайтинг здесь строится на трех столпах.

Блок 1: Анкеты и самодекларации (Self-Assessment)

Клиент заполняет объемные опросники, подтверждая наличие базовых контролей: многофакторной аутентификации (MFA), систем резервного копирования (Backup & Recovery), защиты конечных точек (EDR), сегментации сети и процессов управления инцидентами. *Проблема:* Анкеты субъективны. Клиент может искренне верить, что у него "надежная защита", но заблуждаться.

Блок 2: История инцидентов

Страховщик анализирует убыточность клиента за прошлые периоды и сопоставляет её с глобальными данными по отрасли. *Проблема:* В кибербезопасности "прошлые успехи не гарантируют будущего". Отсутствие взломов за 5 лет не означает, что завтра не прилетит 0-day эксплойт.

Блок 3: Техническое подтверждение (Hard Evidence)

Именно здесь на сцену выходит **пентест**. Современные рекомендации европейского регулятора ENISA и международной ассоциации IAIS гласят: риски киберстрахования невозможно адекватно оценить только по бумагам. Требуется техническая валидация. Сюда входят:

- Отчеты по тестированию на проникновение (Pentest Reports).
- Результаты внешнего сканирования периметра (Vulnerability Scanning).
- Аудиты соответствия стандартам (ISO 27001, PCI DSS, NIST).

Трансформация роли пентеста

На международном рынке (а следом и в РБ) регулярный пентест стал "золотым стандартом" андеррайтинга. Страховые брокеры прямо заявляют: анкета — это ваши

"обещания", а пентест — это проверка того, насколько эти обещания соответствуют суровой реальности.

Отчет по пентесту перестал быть "технической бумажкой". Теперь это **финансово-правовой документ**. При наступлении страхового случая его будут изучать не только ваши "безопасники", но и высокооплачиваемые юристы страховой компании, андеррайтеры и эксперты по компьютерной криминалистике (Forensics).

3. Взгляд Андеррайтера: как читают ваш отчет по пентесту

Андеррайтер — не хакер. Он риск-менеджер. Ему не интересно, какой именно скрипт использовал пентестер для обхода WAF. Ему интересно, что это значит для денег страховой компании. Рассмотрим упрощенную модель того, как андеррайтер анализирует отчет.

3.1. Свежесть и Охват (Scope)

Первое, на что смотрят — дата. Отчет старше 6–12 месяцев считается неактуальным. В мире, где новые CVE выходят каждый день, прошлогодний отчет — это история древнего мира. Второй момент — охват. Если вы страхуете весь бизнес, а пентест проводили только для сайта-визитки, игнорируя внутреннюю сеть, Active Directory и облачную инфраструктуру, такой отчет будет признан нерепрезентативным. Страховщик увидит "слепые зоны", в которые заложит повышенный коэффициент риска.

3.2. Критичность и природа уязвимостей

Андеррайтер смотрит на Summary отчета. Его интересуют уязвимости уровня Critical и High. Особенно те, которые напрямую ведут к реализации рисков вымогателей (Ransomware) или утечке данных:

- RCE (Remote Code Execution) — возможность удаленного выполнения кода.
- SQL Injection — доступ к базам данных.
- Отсутствие MFA на точках входа (VPN, RDP).
- Misconfiguration в облаках (открытые S3 бакеты).

3.3. Реальность контролей (Reality Check)

Пентест — это детектор лжи для вашей анкеты.

- *В анкете*: "У нас везде внедрена строгая парольная политика".
- *В отчете*: "Найдены учетные записи с паролями 123456, осуществлен брутфорс админской учетки". Такое расхождение — красный флаг. Оно говорит о том, что система управления информационной безопасностью (СУИБ) не работает.

3.4. Статус устранения (Remediation Status)

Самый важный пункт. Наличие критических уязвимостей в отчете — это нормально (идеальных систем не бывает). Ненормально — их наличие **после** завершения проекта. Страховщик требует план ремедиации (исправления) и подтверждение того, что "дыры" закрыты. Это может быть ретест (re-test) от той же команды пентестеров или отчет сканера уязвимостей.

3.5. Доказательство "Due Care" (Должной осмотрительности)

В англосаксонском праве (и де-факто в международном страховании) есть понятие **Due Care**. Это демонстрация того, что компания действовала разумно и ответственно. Пентест с последующим устранением багов — это лучшее юридическое доказательство того, что вы не "сидели сложа руки". Андеррайтер видит проактивную позицию.

Результат: Чистая картина снижает размер премии. Наличие старых, незакрытых "критов" ведет к исключениям из покрытия или требованию закрыть уязвимости *до* начала действия полиса (condition precedent).

4. Сценарий катастрофы: "Уязвимость была в отчете, но вы ее не исправили"

Давайте смоделируем ситуацию, которая является ночным кошмаром для любого юриста компании.

Сценарий:

- Компания заказывает пентест. Аудиторы находят критическую уязвимость на внешнем периметре (например, уязвимый VPN-шлюз).
- Отчет кладется "в стол" из-за нехватки бюджета или времени админов. Уязвимость не устраняется.
- Компания покупает полис киберстрахования.
- Происходит атака вируса-шифровальщика именно через этот уязвимый шлюз.
- Компания подает заявление на выплату убытка (который может составлять сотни тысяч долларов).

Реакция Страховщика: Страховая компания проводит расследование (Forensic investigation). Эксперты поднимают старый отчет по пентесту и видят, что "ворота были открыты", и вы об этом знали.

Результат — Отказ в выплате.

Почему? Потому что большинство киберполисов содержат исключения, касающиеся

"Known but unpatched vulnerabilities" (известных, но не устраненных уязвимостей) или **"Prior Knowledge"** (предварительного знания).

Юридическая позиция страховщика будет железобетонной:

- Страхователь заранее знал о высоком риске.
- Страхователь не принял разумных мер для минимизации риска (нарушение принципа *mitigation of damages*).
- Страхователь нарушил условия договора, требующие поддержания определенного уровня защищенности.

Это не теоретический кейс. В зарубежной практике (а скоро и в белорусской судебной практике) такие споры решаются не в пользу клиента. Если вы заявили в анкете, что у вас все безопасно, а пентест показал обратное, и вы промолчали — это может быть квалифицировано как **Misrepresentation** (введение в заблуждение), что делает договор ничтожным.

Для РБ этот подход будет логично перенесен в договорную практику: даже без спецзакона, страховой договор — это гражданско-правовой контракт. Если в нем закреплена обязанность "поддерживать средства защиты в актуальном состоянии", игнорирование отчета пентестеров — это прямое нарушение контракта.

5. Как превратить пентест в инструмент экономии и гарантий

Качественный пентест в связке с процедурой исправления ошибок (Remediation) работает на бизнес в двух направлениях: снижает стоимость страховки на входе и гарантирует выплату на выходе.

5.1. Снижение премии (Cost Reduction)

Чем "чище" ваш финальный отчет (после ретеста), тем привлекательнее вы для андеррайтера.

- Выявление ошибок конфигурации (дырявые фаерволы, открытые RDP) до прихода страховщика позволяет избежать повышающих коэффициентов.
- Исправление проблем до заполнения анкеты страхует вас от обвинений в ложных сведениях.
- Для высокорисковых отраслей (финтех, e-commerce, медицина) наличие регулярных пентестов часто является обязательным условием для получения покрытия вообще. Без этого с вами просто не будут разговаривать.

5.2. "Страховка от отказа" (Claim Guarantee)

В процессе урегулирования убытка (Claims Handling) страховщик всегда ищет причину для снижения выплаты. Отчет по пентесту с подтверждением устранения уязвимостей — ваш щит. Он показывает:

- Клиент не просто декларировал меры (как в анкете), а проверял их на практике.
- Система безопасности управлялась, процессы работали.
- На момент инцидента известные критические дыры были закрыты (а значит, атака произошла через что-то новое, например, 0-day, что является чистым страховым случаем).

Без пентеста страховщик может заявить о "грубой неосторожности" (gross negligence). С хорошим пентестом ваша позиция в споре становится доминирующей.

6. Три аналогии для бизнеса: объясняем "на пальцах"

Чтобы донести важность этой связки до финансового директора или собственника бизнеса, используйте следующие аналогии.

Аналогия 1: Медосмотр перед ипотекой

Представьте, что банк страхует вашу жизнь при выдаче крупного кредита. Пентест — это медосмотр. Врач находит у вас критическое заболевание, но вы игнорируете лечение, выбрасываете рецепты и живете как раньше. Через год наступает страховой случай именно по этой болезни. Страховая скажет: "Вы знали диагноз, могли лечиться, но не стали. Это не случайность, это ваш выбор". В ИБ то же самое: критическая уязвимость — это диагноз. Не лечить её — значит потерять право на страховку.

Аналогия 2: Тормозные шланги и КАСКО

Вы страхуете автомобиль. На сервисе (пентест) вам выдают акт: "Тормозные шланги прогнили, ездить опасно". Вы кидаете акт в бардачок и продолжаете ездить. Случается ДТП из-за отказа тормозов. Страховщик поднимает акты сервиса, видит, что вы знали о неисправности, и отказывает в выплате по КАСКО. Вы сознательно эксплуатировали неисправное ТС. В киберстрахе "дырявый" софт — это ваши прогнившие тормоза.

Аналогия 3: Охранный сигнализация

В анкете на страхование квартиры вы пишете: "Есть сигнализация, подключена к пульту". Вам дают скидку. По факту сигнализация сломана, датчики заклеены скотчем, а код написан на стене. Происходит кража. Полиция и аджастеры видят, что

система не работала. Страховщик отказывает, так как вы нарушили условия договора и предоставили недостоверные сведения для получения скидки. Если пентест показывает, что ваша заявленная "супер-защита" обходится школьником за 5 минут — для страховщика это сигнал, что вы его обманули.

7. Практическое руководство для компаний в РБ

Несмотря на молодость рынка, действовать нужно уже сейчас, опираясь на лучшие мировые практики (best practices). Логика "Пентест ↔ Андеррайтинг ↔ Выплата" универсальна.

Чек-лист для подготовки к киберстрахованию:

- **Делайте не формальный, а "страховой" пентест.**
При заказе пентеста сразу сообщайте подрядчику, что результаты пойдут страховщику. Акцентируйте внимание на проверке зон, критичных для андеррайтинга: надежность MFA, изоляция бэкапов (чтобы их не зашифровали вместе с данными), сегментация сети, защита административных доступов.
Требуите от подрядчика: Описание рисков должно быть понятно не только хакерам, но и юристам.
- **Правило "Zero Critical".** Ведите во внутренние регламенты железное правило: отчет по пентесту не считается закрытым, пока не устранены все уязвимости уровней Critical и High. Либо должны быть внедрены компенсирующие меры (например, если нельзя обновить старый сервер, он должен быть полностью изолирован из сети).
- **Документируйте каждый шаг.** Ретесты, акты приемки работ по ИБ, отчеты сканеров после обновлений — все это должно храниться. В суде или при споре о выплате работает правило: "Чего нет на бумаге, того не было".
- **Синхронизация Анкеты и Реальности.** Никогда не заполняйте анкету страховщика "по памяти". Перед заполнением откройте последний отчет по пентесту. Если в анкете вопрос "Используете ли вы MFA везде?", а в отчете пентестера сказано "Найден RDP без MFA", пишите правду или срочно исправляйте. Ложь в анкете (Misrepresentation) — самый быстрый способ потерять деньги, уплаченные за полис.
- **Регулярность — залог покрытия.** Страховщики требуют актуальности данных. Ежегодный пентест — это минимум. При существенных изменениях инфраструктуры (миграция в облако, слияние компаний) нужен внеплановый тест.

Итог

Киберстрахование в Беларуси перестает быть экзотикой и становится инструментом выживания бизнеса. Но этот инструмент работает только в умелых руках.

Качественный пентест и, что еще важнее, **системное устранение** найденных уязвимостей превращают вашу компанию из "черного ящика" с неизвестными рисками в прозрачный и управляемый актив. Для страховщика это означает снижение вероятности крупного убытка, а для вас — низкую стоимость полиса и железобетонные основания требовать выплату, если киберкатастрофа все-таки произойдет.